

Reverse Engineering

For Dummies

The “what if?” user

About me

- Software Engineer +6 years
 - NSA -> Contractor -> Private sector
- Lots of side projects
 - Open source - JWK Set
 - SaaS platform
 - Reverse engineering
 - Other stuff
- Wrote 3 CTF challenges
 - Some answers in this presentation



Introduction



Kitty Letter - Android Game

For each

1. Experienced User Objective
2. Flaws & Techniques
3. Play tech lead



Concept2 - Waitlist



Auction House - Pub/Sub

Introduction

These projects are each

- At least 3 years old
- Low stakes
- Issues irrelevant today

Project

Today's status

Kitty Letter

- Last updated 3 years ago
- No real issues anyways

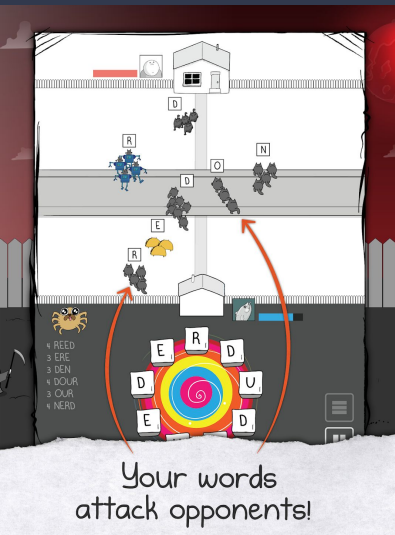
Concept 2

- Waitlist decommissioned

Auction House

- Issues fixed 🎉

Kitty Letter – Android Game



Last update: June 12, 2021

Looking for Kitty Letter?

This app isn't available for your device because it was made for an older version of Android



Wife	Micah
Bachelor's in English	Requires spellcheck to communicate
Straight A student*	Kind of stupid

*Except the class she met me in

Accepted	Not Accepted
Sunray	Sunhat
Doody	Angus
Newb	Muslim
Tacocat	Hacky
Ketchupier	



Kitty Letter – Android Game

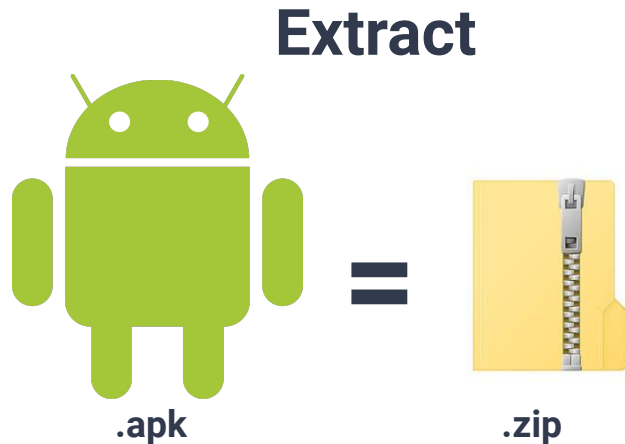
Objectives

1. Find custom word list
2. Make custom cheat program

Kitty Letter – Android Game

Download the Android app files

- Use Android device, extract from device
- Custom software: desktop app or browser extension
- Website that generates a direct download link
- Use an APK mirror website



Kitty Letter – Android Game

```
$ tree kitty-letter-1-09-05 -L 2
```

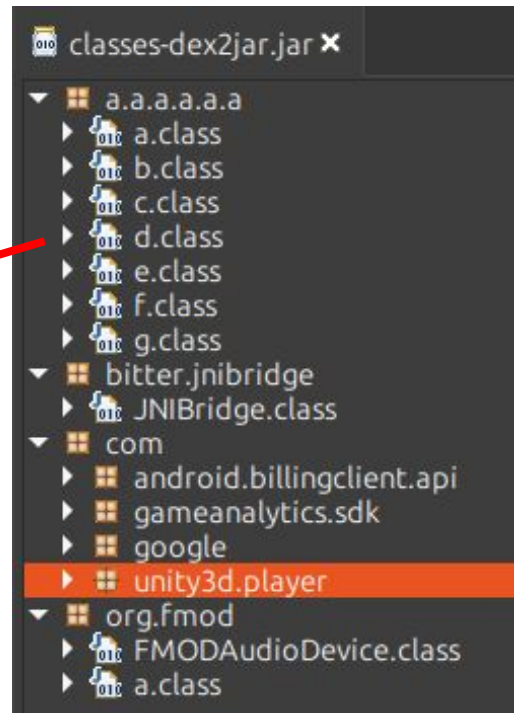
```
├── AndroidManifest.xml
├── assets
│   └── bin
├── billing.properties
├── classes.dex
├── lib
│   └── armeabi-v7a
├── META-INF
│   ├── BNDLTOOL.RSA
│   ├── BNDLTOOL.SF
│   └── MANIFEST.MF
├── res
│   ├── mipmap-anydpi-v26
│   ├── mipmap-hdpi-v4
│   ├── mipmap-ldpi-v4
│   ├── mipmap-mdpi-v4
│   ├── mipmap-xhdpi-v4
│   ├── mipmap-xxhdpi-v4
│   └── mipmap-xxxhdpi-v4
│   └── xml
├── resources.arsc
└── stamp-cert-sha256
```

Decompile DEX

- <https://github.com/pxb1988/dex2jar>
- <https://www.pnfsoftware.com/jeb/>

Decompile .class

- <https://github.com/java-decompiler/jd-gui>



Kitty Letter – Android Game

\$ grep -R butter

grep: assets/bin/Data/data.unity3d: binary file matches

How to extract assets from a Unity 3D file?

```
60("ic..Autyr...M-..'..a.$...DtyraX5....".
Sutyls..AtyleU .r.....$...Ration.<....G..
;.1tyl~.5345.."ed,.....*.... .."utq[bbutu
t I."ty..sttstock.....! 8..Rtts 1k.#tr...x
.....d.R.....Sttony0.rtttonwool.....s.....
.6!.4U.!onZ.$03..Chook...ttonhole\.....3..
2.."er.I...ld 1F..uttonbush....ball 13#.
tt..9.$ck .ltto.Z.....7....Q.89..t...I.C
le 2#.Sinskyn...."is.....(....g2."iehB4b
ut...1..3hea.E2butj....!ry`....Rrwort....
2eed.....buttern!...]....t....Bmilk.&.
....#35...etb%22=.....2K..]...6...leriIx.=
.Bhornk(.]....%33 .....Bfish....2ats#,.
....bered 9..ctercup.0.,.1cup....3bur.".
.....call 23h..ae....d....e..Bttal..Abut
t,..,..3ohs .3toh,....7l..ln.1butL..8;.
.u....lW."37(..lb..3...*....d.ltes..Sbute
o..Quteon.."34.....#eo:.rtenes 9..3eney
"te0 Autch 2o u t lch Bchersi
```



Bunny83

Jun 2011



That doesn't sound like you are developing games (more like you try to steal some content?)

This repository has been archived by the owner on Jan 21, 2023. It is now read-only.



AssetStudio Public archive

Watch 449

Fork 2.5k

Star 12.7k

master

2 Branches 31 Tags

Go to file

Code

About



support 2022.1

d158e86 · 2 years ago

574 Commits

.github/workflows

Create build.yml

2 years ago

AssetStudio.PInvoke

update project file

2 years ago

AssetStudio

support 2022.1

2 years ago

AssetStudioFBXNative

Update project

3 years ago

AssetStudioFBXWrapper

update project file

2 years ago

AssetStudioGUI

update enum

2 years ago

AssetStudio is a tool for exploring, extracting and exporting assets and assetbundles.

unity unity3d

Readme

MIT license

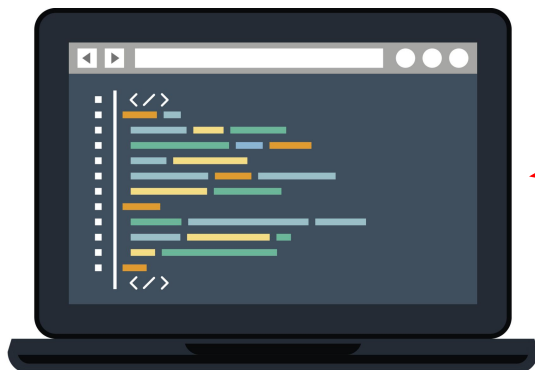
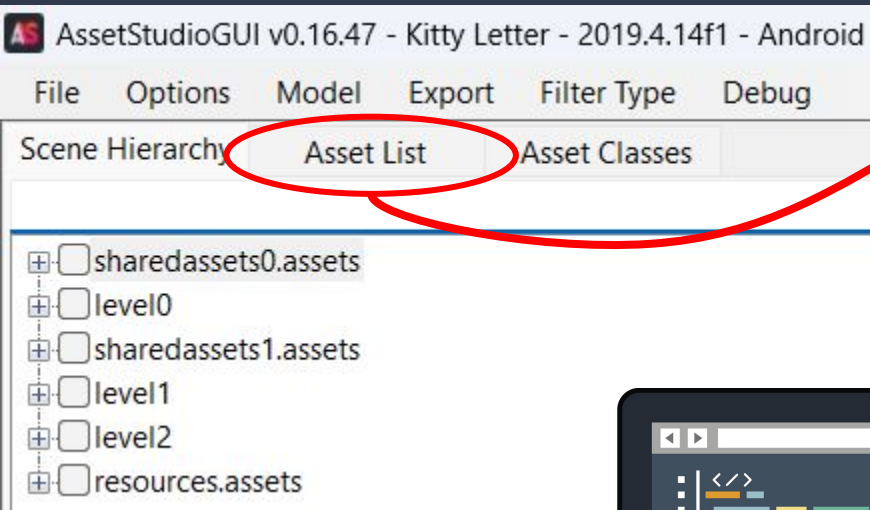
Activity

12.7k stars

449 watching

2.5k forks

Kitty Letter – Android Game



AssetStudioGUI v0.16.47 - Kitty Letter - 2019.4.14f1 - Android

File Options Model Export Filter Type Debug

Scene Hierarchy Asset List Asset Classes

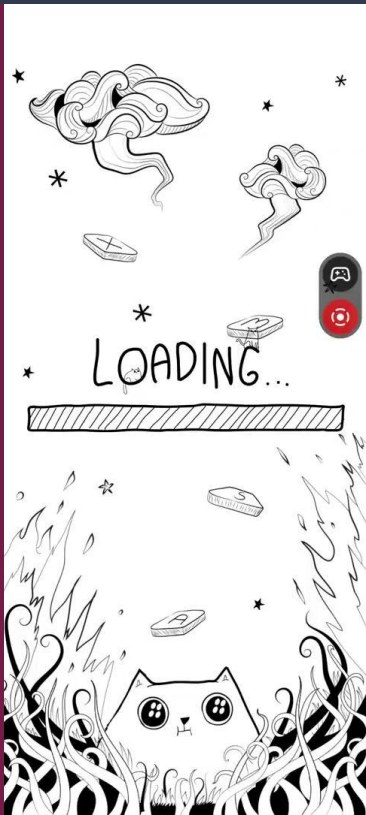
Filter

Name	Container	Type	PathID	Size
sp_level_fork		TextAsset	112	1076
words_alpha2		TextAsset	110	164...
Easier Word List		TextAsset	111	645...
sp_level_final		TextAsset	113	1156
sp_level_10		TextAsset	114	1120
sp_level_03		TextAsset	99	1012
wordy_arcade_level		TextAsset	97	952
sp_level_hotsauce		TextAsset	96	1076
Moderate Word List		TextAsset	95	102...
sp_level_04		TextAsset	109	1040
sp_level_tacocat		TextAsset	98	1240
listofwords_6	words/li...	TextAsset	189	119...
sp_level_01		TextAsset	100	800
Achievements		TextAsset	101	1308
listofwords_9	words/li...	TextAsset	184	340...
listofwords_12	words/li...	TextAsset	185	159...
listofwords_2	words/li...	TextAsset	186	452
listofwords_14	words/li...	TextAsset	187	809...
LineBreaking Followin...	linebrea...	TextAsset	203	312
listofwords_10	words/li...	TextAsset	202	297...
listofwords_8	words/li...	TextAsset	201	313...

Kitty Letter – Android Game

```
$ ./kittyletter trluaef
```

```
.  
.   
.   
ultra  
urate  
artel  
later  
fetal  
farle  
feuar  
feral  
lutea  
artful  
ferula  
falter  
fluter  
earful  
tearful  
refutal
```



Tech Lead Time

- No recommended changes 🎉
 - Fits threat profile
 - Only marginally better at cheating

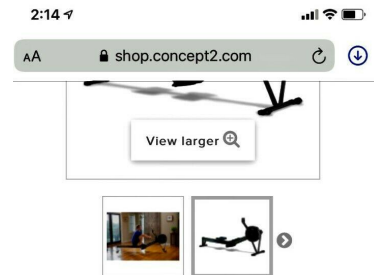
One step further?

- Obfuscate text assets
- API to check word points - online only
 - Issue license per download and verify

Concept 2 – Waitlist



2020



Model D RowErg

Part Number: 2712

The dependable performance of the Concept2 Model D RowErg has made it the best selling indoor rower in the world. Features a 14 inch frame height, nickel-plated chain, powder coat with matte finish, and Concept2's most advanced Performance Monitor, the PM5. Available in black. Smartphone Cradle included.

Print

\$900.00

Quantity

1 - +



Model D Indoor Rower

Part Number: 2711

Concept2's best seller, the Model D offers dependable performance, a 14 inch frame height, nickel-plated chain, powder coat with matte finish, and our most advanced Performance Monitor, the PM5. Available in black or gray. Smartphone Cradle included.

This item is currently unavailable to order online. Please join our [wait list](#).

Print

\$900.00

Join Wait List



View larger

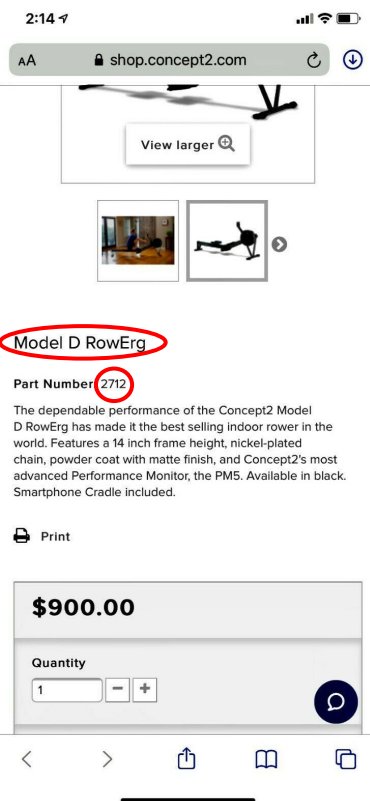


Concept 2 – Waitlist

Objective

Bypass the waitlist

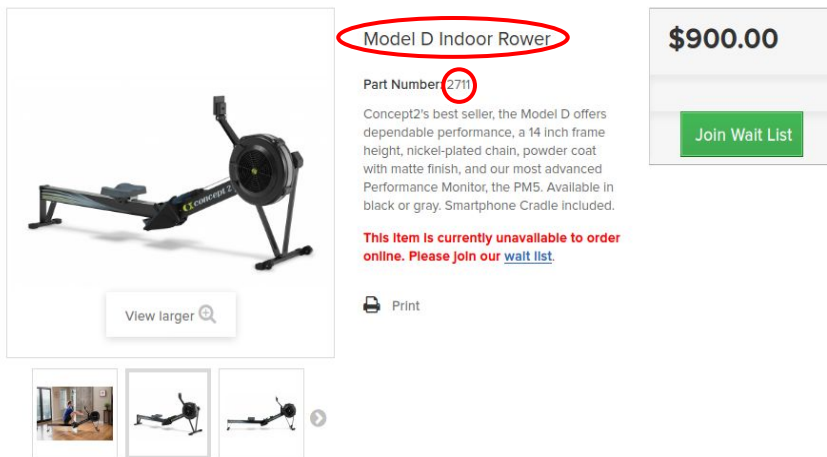
Concept 2 – Waitlist



I learned two things immediately

1. Hustler this thinks the waitlist is a link
2. That link is a page on shop.concept2.com

<https://shop.concept2.com/indoor-rowers/298-model-d-with-pm5.html>



Troubleshooting

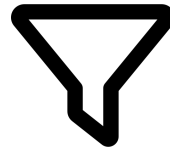
- ✓ See if it's linked directly anywhere
- ✓ Try URL query parameters
- ❑ Learn URL structure

Concept 2 – Waitlist

<https://shop.concept2.com/indoor-rowers/298-model-d-with-pm5.html>

<https://shop.concept2.com/indoor-rowers/311-model-e-with-pm5.html>

<https://shop.concept2.com/-/{000-999}-.html>



Equivalent URLs

<https://shop.concept2.com/indoor-rowers/298-model-d-with-pm5.html>

<https://shop.concept2.com/-/298-.html>

<https://shop.concept2.com/anything/298-anything.html>



View larger

Model D RowErg

Part Number: 2712

The dependable performance of the Concept2 Model D RowErg has made it the best selling indoor rower in the world. Features a 14 inch frame height, nickel-plated chain, powder coat with matte finish, and Concept2's most advanced Performance Monitor, the PM5. Available in black. Smartphone Cradle included.

Print

\$900.00

Quantity

1

☒ **ADD TO CART**

`<span>Join Wait List</span>`

Concept 2 – Waitlist

<https://micahparks.com/rvasec-survey>

Can I use this waitlist link?

- ✓ Add it to my cart
- ✓ Checkout shipping screen
- ✓ Checkout payment screen
- ❑ Checkout review screen

Should I use this waitlist link?

1. Is this ethical?
2. Do I want to spend \$1,100 on a rower?



I got my waitlist email the next Monday.
It was the same link I found, no URL query parameters.

Concept 2 – Waitlist

<https://micahparks.com/rvasec-survey>

Business Justification (Secondary Market)

- Hustlers
 - Dropshipping
 - Selling waitlist access
 - Price gouging real customers
- Similar to Bluesky waitlist

Tech Lead Time

- Build a real waitlist system
 - Per account, shipping address, etc
 - Unique one-time coupon codes
- Prevent web scraping
 - Randomly generated IDs
 - CAPTCHA
 - Rate limiting
 - WAF (Cloudflare)

Auction House – Pub/Sub

<https://micahparks.com/rvasec-survey>



A better version of my Craigslist cars project

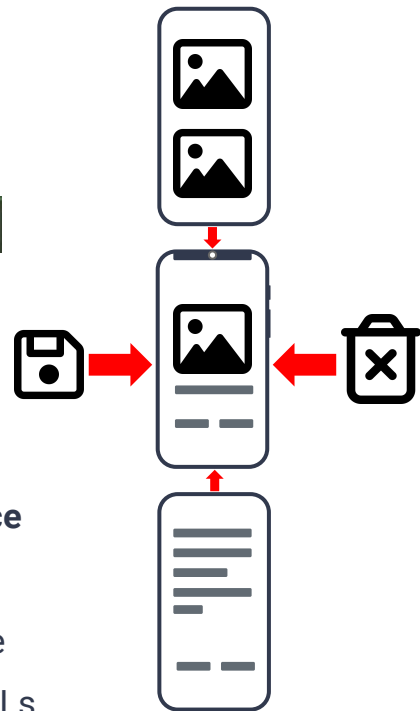
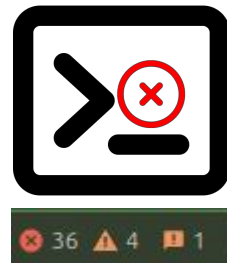


\$1,150.00

★★★★☆ (4)

Custom frontend? Play nice

- Client side rate limit
- Use database/cache
- Only store image URLs



Auction House – Pub/Sub

<https://micahparks.com/rvasec-survey>

Objectives

1. Investigate PubNub
2. Incorporate into Tinder-style app?

Auction House – Pub/Sub

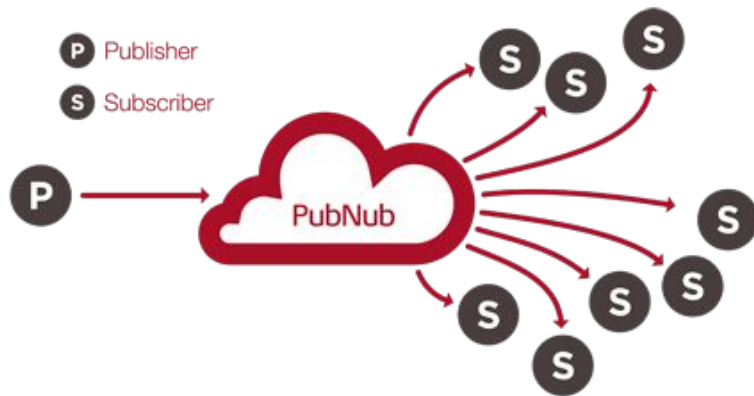
<https://micahparks.com/rvasec-survey>

```
<script>
const uuid = PubNub.generateUUID();

const pubnub = new PubNub({
  subscribeKey: 'REDACTED',
  uuid: uuid,
  restore: true,
  listenToBrowserNetworkEvents: false
});

const uuid2 = PubNub.generateUUID();

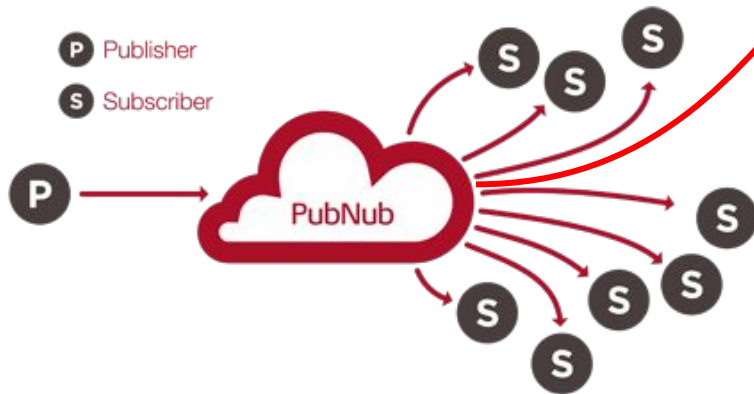
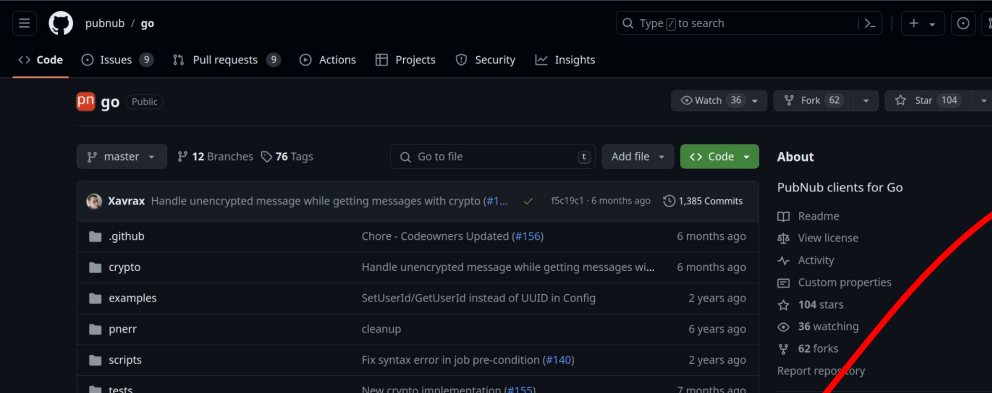
const userpubnub = new PubNub({
  subscribeKey: 'REDACTED',
  uuid: uuid2,
  restore: true,
  listenToBrowserNetworkEvents: false
});
</script>
```



```
function InitPubnub () {
  pubnub.unsubscribeAll ();
  pubnub.subscribe ({
    channels: ['bid_refresh', 'auction_halt',
      'bid_groupitem_refresh' ],
    withPresence: false
  });
  pubnub.addListener (existingListener);
}
```

Auction House – Pub/Sub

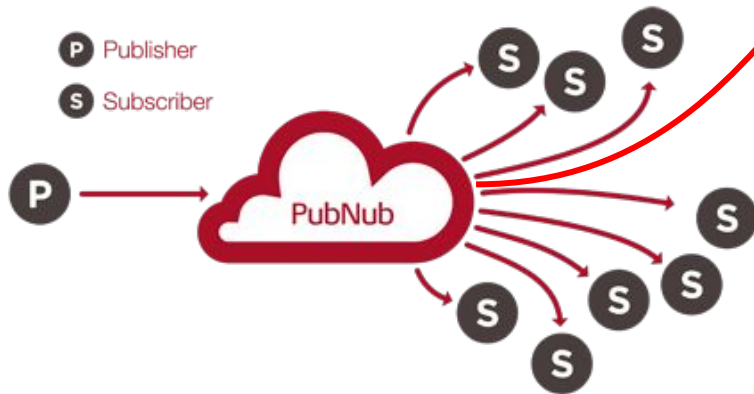
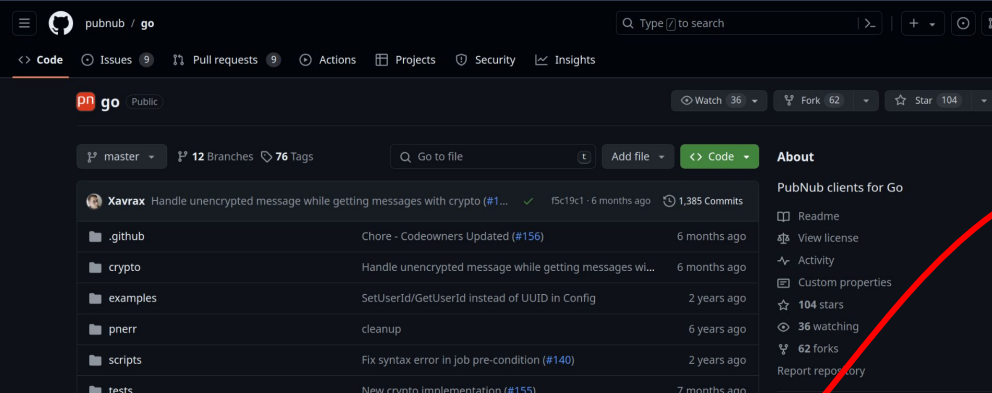
<https://micahparks.com/rvasec-survey>



Auction		Bidder	
ID	Item	ID	Bid
Name	ID	Name	Increment
End date	Name	Bid count	Top bid
...	Private status	...	Current bid
	...		...

Auction House – Pub/Sub

<https://micahparks.com/rvasec-survey>

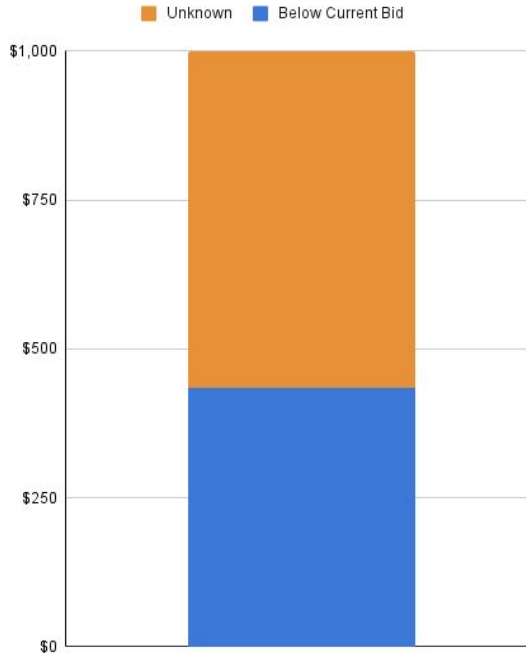


Auction		Bidder	
ID	Item	ID	Bid
Name	ID	Name	Increment
End date	Name	Bid count	Top bid
...	Private status	...	Current bid
	...		...

Auction House – Pub/Sub

<https://micahparks.com/rvasec-survey>

Seller Fraud (Risk Mode)



Seller Fraud (Easy Mode)



Tech Lead Time

- Audit Pub/Sub system
 - Messages sensitive or PII
 - API key authorization
 - Separate channels
 - Evidence of fraud?
- Prevent web scraping
 - CAPTCHA
 - Rate limiting
- Check console errors before deploy 😊

Conclusion

<https://micahparks.com/rvasec-survey>



Kitty Letter - Android Game

For each

1. Experienced User Objective
2. Flaws & Techniques
3. Play tech lead



Auction House - Pub/Sub



Concept2 - Waitlist

That's it

<https://micahparks.com/rvasec-survey>

More about me

- Say hi, I want to meet people
 - <https://micahparks.com/contact>
- Follow me on GitHub
 - <https://github.com/MicahParks>
- Available for hire! Full time or contract

For the young person in your life

- [IntelligenceCareers.gov](https://www.intelligencecareers.gov) - Student Programs
 - Fastest way to get a security clearance
 - Salary, housing, and maybe a car
 - NSA - Cooperative Education (Co-op)
 - NSA - STOKES Scholarship

Cheap online CS Master's Degree

- OMSCS - Georgia Tech (\$7,000 - \$8,000)
 - <https://omscs.gatech.edu/specializations>

